

Lab 4: Algorithmic Impact Assessment

AI Talent Sourcing Assistant: Required Deliverables

Prepared by: Nishanth Ravula

Course: PhD 832: Ethics in Responsible AI

Date: September 20, 2026

Contents

- 1. Completed Algorithmic Impact Assessment Evidence:** System Description and Section 2.3 (Data Collection and Selection) portal screenshots, embedded in the full Formal Report, with identified risks and the final recommendation.
- 2. Data Integrity Justification Brief:** ~500 words on the tension between GDPR data minimization and the need for representative data.
- 3. Deployment Decision:** Go / Conditional Go / No-Go recommendation, defended against likelihood and magnitude of harm, disparate effects, data-governance weaknesses, legal and compliance concerns, and mitigability.

Algorithmic Impact Assessment

AI Talent Sourcing Assistant: Formal Report

1. System Description

System Name: AI Talent Sourcing Assistant

Purpose: To assist recruiters by automatically scoring and ranking job applicants on two dimensions (“cultural fit” and “growth potential”) using information drawn from applicant-submitted resumes and from applicants' publicly viewable LinkedIn profiles, and to produce a ranked candidate list for recruiter review.

Organization / Owner: A multinational employer's Talent Acquisition function, jointly owned by Human Resources (business owner) and an internal People Analytics / Data Science team (technical owner), with active EU hiring bringing GDPR and the EU AI Act into scope. The organization's AI governance program is moderately mature but incomplete: no standing AI ethics board and no completed DPIA for this system.

Responsible Team Members: HR/Talent Acquisition lead (business sponsor); Data Science/ML team (builds and maintains the models); Legal/Privacy counsel; IT/Security (LinkedIn data-ingestion pipeline). Points of contact: Nishanth Ravula, Talent Acquisition Technology Lead; Tony Stark, Privacy/Legal Counsel.

Anticipated Use: Continuous use across all open requisitions. Recruiters receive a ranked shortlist per role rather than reviewing the full applicant pool; lower ranked candidates may be deprioritized indefinitely. Projected release date: April 1, 2027, allowing time for the remediation roadmap in Section 5 to be completed first. Final hiring decisions formally rest with human recruiters, though the ranking materially narrows which candidates receive any human attention at all, a distinction central to the EU AI Act analysis in Section 4.

Data Inputs: (1) resumes submitted directly by applicants; (2) publicly viewable LinkedIn profile content, matched by name or email and obtained by scraping or a third-party enrichment vendor.

Outputs: A “cultural fit” score and a “growth potential” score per candidate, and a composite rank used to sequence recruiter review.

Could a non-AI system serve the same purpose? A structured, rules based scorecard or resume only keyword filtering could perform the same triage without the LinkedIn profiling that drives this assessment's core risks. AI is preferred here for scale and speed, not because the task is otherwise infeasible. If speed-at-scale is the only benefit the AI version adds over that non-AI alternative, it fails a basic proportionality test once weighed against the Near certain notice violation and proxy discrimination exposure in Section 3; a marginal efficiency gain does not justify a risk of that likelihood and magnitude, which is itself part of the basis for the No-Go recommendation in Section 5.

Figure 1 below is the completed EqualAI portal evidence for this section.

Description	Description Provide an initial description of the system, project overview, and points of contact who will be responsible for the audit or AI system. Note: You may want to include unique ID, tags or other project identifiers to facilitate identification and record keeping downstream.
Context	
Classification	
Bias	
Cost/Benefits Evaluations	
Third-party Technologies	
Legal and Compliance	
Final Decision	

1. Working name of AI system and owner/organization:

AI Talent Sourcing Assistant

2. Briefly describe the AI system under consideration:

An AI-assisted recruitment tool that scores and ranks job applicants on two dimensions "cultural fit" and "growth potential" using information drawn from applicant submitted resumes and from applicants' publicly available LinkedIn profiles. The system produces a ranked candidate list that recruiters use to prioritize which applicants receive further human review.

3. List team members, their roles and responsibilities:

HR/Talent Acquisition Lead: business sponsor; defines scoring criteria and use policy. ML Team: builds and maintains the ranking models.
Legal/Privacy Counsel: reviews notices and regulatory exposure.
IT/Security: manages the LinkedIn data-ingestion pipeline and access controls. (If LinkedIn data isn't scraped in-house)
Third-party HR-technology vendor: supplies enriched candidate profiles.

4. Projected (or past) date(s) of AI system release:

2027-04-01

5. Who is the point of contact for the AI project? Who is the point of contact for the Impact Assessment?

Nishanth Ravula, Talent Acquisition Technology Lead — nravula@aiassist.com
Impact Assessment: Tony Stark, Privacy/Legal Counsel — tony.stark@aiassist.com

Figure 1. EqualAI AIA Portal, Description tab, as completed.

2. Data Collection, Selection, and Bias: Findings

The training data is a historical set of past applicants' resumes, LinkedIn profiles, and hiring or performance outcomes. Resumes were collected directly through the application portal; LinkedIn data was obtained through scraping or a third-party enrichment vendor and matched to applicants by name or email. Applicants were very likely not informed that LinkedIn data specifically would be used to score them, since the scenario has them told only that automated tools “may assist.” Several scoring inputs (employment history, tenure, written profile language, and professional or extracurricular affiliations) are recognized proxies for protected characteristics such as sex, disability, age, and national origin. These two findings (an unresolved notice gap and embedded proxy risk) are the load bearing facts behind the risk ratings in Section 3 and the legal analysis in Section 4.

No documented process describes how the historical HR data was cleaned, curated, or validated before training. Baseline technical cleaning (deduplicating applications, normalizing job-title/date fields, matching resumes to LinkedIn profiles) is treated here as the working baseline, but no evidence indicates the hiring-outcome labels defining “cultural fit” and “growth potential” were validated against actual performance records rather than an unaudited manager impression, and no independent reviewer checked the training population for the survivorship bias this creates.

Applying the NIST SP 1270 bias taxonomy (NIST, 2022), all three categories are implicated and untested. Statistical/computational; the training population is a non random sample of past hires, and nearly every scoring feature is a proxy rather than a direct measure of “fit” or “potential.” Systemic: the model reproduces the organization's own historical hiring pattern, and no independent ethics or data governance reviewer sits outside the team that built and benefits from it. Human cognitive; LinkedIn was very likely chosen as a source because it was easy to scrape, not because it was shown to be the most job-relevant or minimally invasive option, and no ethicist, sociologist, or psychologist was consulted on what “cultural fit” should measure. No bias mitigation is currently implemented; an independent adverse-impact audit and quarterly re-testing after any retraining are required before deployment can be reconsidered.

The screenshots below are the completed EqualAI portal evidence for this section. Questions 1–5 appear in Figure 2; Questions 6–11, including the representativeness, informed-consent, and policy/legal-compliance answers, appear in Figure 3.

Section 2.3. Data collection and selection
Many AI system risks and vulnerabilities can be traced to insufficient testing and evaluation processes as well as oversight in data collection and curation.

1. How was the data collected, cleaned, and curated? Who was involved in the data collection process?

Training data is a historical set of past applicants' resumes, LinkedIn profiles, and hiring/performance outcomes. Resumes were collected directly through the application portal; LinkedIn data was obtained via scraping or a third-party enrichment vendor, matched to applicants by name or email. The Data Science/ML team selected and curated the training population; HR/Talent Acquisition supplied the outcome labels. No independent data-governance or ethics reviewer was involved.

2. What, if any, are known errors, sources of noise, or redundancies in the data?

LinkedIn data is self-reported and unverified, so it can be incomplete, outdated, or strategically curated. Name/email matching between resumes and LinkedIn profiles can produce false merges or missed matches. Historical performance-rating criteria may also be inconsistent across the collection window.

3. Over what time-frame was the data collected?

A rolling multi-year window (roughly the prior 3–5 years of hires), needed to accumulate enough hiring-outcome history to label "growth potential." LinkedIn data is a point-in-time snapshot taken at application, not continuously monitored.

4. [After extended use(s)] Is the training and testing data still representative of the current operational environment(s)?

No

5. What is the variable selection and evaluation process?

"Cultural fit" draws on employment history, tenure, job-title similarity, written profile language, and professional/extracurricular affiliations. "Growth potential" draws on education, career progression, prior roles, certifications, and employment history. Features were selected for statistical correlation with historical outcomes; no fairness or proxy-variable screen was applied, and several inputs are recognized proxies for protected characteristics.

6. If the dataset relates to, or derives from individuals (e.g., their attributes) were they informed about the data collection?

No

Figure 2. Section 2.3, Data Collection and Selection, Questions 1–5.

6. If the dataset relates to, or derives from individuals (e.g., their attributes) were they informed about the data collection?

No

7. Is the training and testing data representative of the demographic population with which the AI system will be used (e.g., age, gender, race, etc.)?

No

8. Do you know why the dataset was created? (e.g., what was the specific need or utility that it was created to fulfill?)

Resume/outcome data was originally collected for individual hiring decisions, not to train a scoring model; LinkedIn data was created by applicants for professional networking, not employer evaluation. Both are repurposed here without a fresh, purpose-specific basis for that repurposing.

9. How do you ensure that the collected data are adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed ('data minimization')? See Article 5 of GDPR for more information.

Resume data is adequate and directly relevant. LinkedIn data is not minimized: a full profile scrape captures fields photo, group memberships, connections not necessary for the stated purpose. Ingestion should be restricted to job-relevant fields only.

10. Do the data collection processes adhere to organization policies related to bias, privacy and security for AI systems?

No

11. Do the data collection processes comply with relevant legal or regulatory requirements applicable to data or AI systems? (See Section 6 on Legal)

No

Figure 3. Section 2.3, Data Collection and Selection, Questions 6–11.

3. Risk Summary

The table below applies a likelihood/magnitude/mitigation framework to the five most significant risks this assessment identified.

Risk	Likelihood / Magnitude	Populations Affected	Mitigation
Notice failure (GDPR Art. 13 & 14)	Near-certain / Moderate–High	All applicants, especially EU	Rewrite notice to name LinkedIn as a source and disclose scoring logic; document a lawful basis for the LinkedIn-specific processing
Proxy discrimination in cultural-fit / growth-potential scores	High / High	Older candidates; caregivers/disabled applicants; non-native-English writers; candidates outside dominant networks	Independent adverse-impact audit; remove or re-weight highest risk features; mandatory human review before adverse decisions
Purpose-limitation violation (repurposed LinkedIn data)	High / Moderate	EU applicants	LinkedIn-specific consent or documented legitimate interest basis; restrict ingestion to job-relevant fields
EU AI Act high-risk obligations unmet	High / Severe	All EU applicants; the organization	Risk-management file, human oversight design, conformity assessment, EU database registration
Third-party data sourcing (scraping / vendor enrichment)	Moderate / Moderate	Organization (legal exposure); applicants (inaccurate scoring)	Use LinkedIn's official data-sharing channels; contractual data-quality terms with any vendor

4. Legal, Compliance, and Third-Party Snapshot

The system's data practices raise findings across three frameworks, summarized below and defended in full in the accompanying Deployment Decision memo:

- **GDPR Notice Failures:** Article 13 governs resumes collected directly from applicants; Article 14 governs LinkedIn data obtained from another source; and the current notice satisfies neither for the LinkedIn stream. No Data Protection Impact Assessment has been completed, though Article 35(3)(a) requires one for systematic profiling of this kind.
- **GDPR Lawful Basis & Special Category Limits:** The asserted Article 6(1)(f) legitimate-interest basis fails its own balancing test against the applicant's privacy interest, and legitimate interest could not cure this for the same affiliation and free text proxies already identified, which plausibly reveal Article 9 special-category data requiring its own exception rather than a mere minimization problem. The human-in-the-loop design likewise does not satisfy Article 22, since the ranking itself, not an independent human judgment, determines which applicants a recruiter ever reviews.
- **EU AI Act High-Risk Classification:** The system is high-risk under Article 6(2) and Annex III point 4(a) (systems used to evaluate and filter job applicants), and none of Article 6(3)'s narrow exceptions applies.

Employment-gap and education/affiliation proxies also create ADA exposure the EEOC's 2022 guidance addresses directly (EEOC, 2022), alongside Title VII exposure; NYC Local Law 144's impact-ratio bias-audit

for sex and race/ethnicity categories would apply to comparable U.S. deployments. LinkedIn profile data is an external, platform controlled source; its terms restrict automated scraping, and if the data is instead purchased through a third-party vendor under a joint controllership arrangement (GDPR Article 26), the organization remains a GDPR controller for it, so the vendor relationship does not transfer away these obligations. The full legal analysis and citations defending this reading, including the Article 6(3) exception-by-exception analysis, are developed in the accompanying Deployment Decision memo.

5. Final Recommendation

Recommendation: NO-GO (Current Iteration)

This system must not proceed to production in its current, as-described form. The Article 13/14 notice failure above is rated Near-certain likelihood and Moderate–High magnitude: a live, uncorrected violation of law, not a residual risk. It compounds with proxy discrimination pathways running through nearly every scoring input. This is not a recommendation to abandon the system; a Go decision can be reconsidered once the organization completes and independently verifies a rewritten LinkedIn notice, a documented lawful basis, an independent adverse impact audit with feature remediation, mandatory human review, the EU AI Act compliance package, and differential privacy model training (assumed budget $\epsilon \approx 2$). The full roadmap, legal justification, and citations supporting this recommendation are developed in the accompanying Deployment Decision memo.

Figure 4 below is the completed EqualAI portal evidence for Section 7.3, Final Decision, recording this same No-Go determination, its risk basis, and its risk tolerance assignment directly in the assessment tool.

Section 7.3. Final Decision

The final decision on go/no go should take into account the risks mapped from previous steps and the organizational capacity for their management.

1. Review and examine documentation, including system purpose and benefits, and mapped potential impacts with associated magnitude and likelihoods.

The AI Talent Sourcing Assistant scores and ranks job applicants on "cultural fit" and "growth potential" using applicant resumes and scraped/vendor-sourced LinkedIn data, producing a ranked shortlist that determines which applicants receive recruiter attention. Its primary benefit is speed and consistency at high application volume a benefit a non-AI, rules-based scorecard could largely replicate, so it must be weighed against the risks below rather than treated as a given. Five risks were mapped and rated:

- (1) GDPR Article 13/14 notice failure — Near-certain likelihood / Moderate–High magnitude;
- (2) proxy discrimination in the cultural-fit and growth-potential scores — High / High;
- (3) purpose-limitation violation from repurposing LinkedIn data — High / Moderate;
- (4) unmet EU AI Act high-risk obligations — High / Severe;
- (5) third-party data-sourcing risk (scraping/vendor enrichment) — Moderate / Moderate. Full detail on each risk, populations affected, and mitigation is in the Risk Summary (Formal Report, Section 3) and the Deployment Decision memo.

2. Document a summary of the system's estimated risk.

Overall estimated risk is High. The two most significant findings compound each other: a live, uncorrected GDPR Article 13/14 notice violation (Near-certain likelihood, Moderate–High magnitude) and proxy-discrimination pathways running through nearly every scoring input (High likelihood, High magnitude) an applicant harmed by a proxy is also an applicant never told the LinkedIn data behind that proxy was collected. The system is additionally high-risk under EU AI Act Article 6(2)/Annex III(4)(a), with none of Article 6(3)'s narrow exceptions available, and no DPIA, independent bias audit, or data-governance reviewer is currently in place. No single mitigation resolves this; a coordinated notice, bias-audit, and compliance remediation plan is required before deployment can be reconsidered.

3. Document why a go/no-go determination was made based on magnitude and likelihood of impact and estimated risk. If a decision is made to proceed, assign the system to an appropriate risk tolerance and align oversight resources with the assessed risk.

Decision: No-Go for the current iteration. A Near-certain/Moderate–High notice violation combined with High/High proxy-discrimination risk is a live legal violation paired with untested discrimination exposure; the evidence does not carry the weight needed to override that combination with a Go. This is not a recommendation to abandon the system; it is assigned High risk tolerance, requiring senior HR/Legal leadership sign-off, until the organization completes and independently verifies

- (1) a rewritten GDPR-compliant notice naming LinkedIn as a source,
- (2) a documented lawful basis for LinkedIn processing,
- (3) an independent bias audit tested for demographic parity and equal opportunity,
- (4) a completed DPIA and EU AI Act Article 43 conformity package,
- (5) an explainable, SHAP/LIME-supported human-review right under Article 22, and
- (6) differential-privacy model training (assumed budget $\epsilon \approx 2$). Once verified and a first quarterly bias-audit cycle shows no adverse-impact breach, the system may be reassigned to Moderate risk tolerance under joint Legal/Data-Science oversight and a Go decision reconsidered. Full defense appears in the Deployment Decision memo (Deliverable 3).

Figure 4. EqualAI AIA Portal, Section 7.3 Final Decision, as completed.

Data Integrity Justification Brief

Minimization vs. Representativeness: AI Talent Sourcing Assistant

The Tension

GDPR Article 5(1)(c) requires personal data to be “adequate, relevant, and limited to what is necessary” for the stated purpose. A recruitment scoring system creates an apparent conflict: evaluating the AI Talent Sourcing Assistant for disparate impact requires visibility into race, sex, age, disability, and national origin, which sounds like it demands more data, not less. The conflict is only apparent. Minimization governs the operational pipeline that scores applicants; it does not forbid a separate, narrowly purposed dataset built to audit fairness. Recital 71 and the narrow special-category carve-outs contemplate exactly this: bounded, safeguarded processing for bias testing, distinct from ordinary business processing.

Does More Data Make the System Fairer?

No: quantity and representation do not coincide; mixing them results in the central flaw of this case. Introducing extra resume or LinkedIn details per applicant such as photos, group memberships, contacts, and profile descriptions significantly increase the space for proxy discrimination without enhancing prediction accuracy, since these details are heavily related to protected characteristics more than to job performance, so the model ends up learning spurious, not better, correlations. Representation, on the contrary, focuses on whom we're including and how target labels are created: training data is selected from applicants the company had already hired, which is survivorship bias. Extracting more information from richer LinkedIn profiles for this same, already-discriminated population does not fix the discriminative nature of the dataset; it simply portrays the same unrepresentative group in more depth. Having a lot but not representing the whole is not upgrading compared to a smaller, but well designed stratified dataset.

What Data Is Necessary Here?

Necessary data for scoring should be limited to structured, job relevant fields the applicant supplies directly under Article 13 notice; verified education credentials, employment dates and titles, and role relevant certifications. Any LinkedIn use should be limited to the same category of fields, collected under an Article 14 notice the applicant actually receives, not a full profile scrape. Profile photographs, group and affiliation memberships, connection lists, and unstructured “written profile language” should be excluded entirely: none are necessary to assess qualifications, and each is a documented proxy for a protected characteristic.

The fairness-testing need is real but belongs in a different, smaller dataset: a purpose-limited, access-restricted sample of self-reported demographic data, collected under separate consent and never fed into the scoring model, used to compute two named statistics rather than a vague “bias check”; demographic parity (comparable selection rates across protected groups) and equal opportunity (comparable ranking rates among qualified applicants across those groups). Both matter; a system can satisfy parity while still under ranking qualified candidates from one group, which only equal opportunity would catch. Minimization governs what ranks candidates; a distinct, safeguarded dataset, audited against these metrics, governs whether the ranking is fair.

Conclusion

Minimization and representativeness only conflict if “representative” is confused with “high volume.” The system needs less data to score candidates than it currently collects, and a narrowly scoped, separately governed sample, not a bigger scrape, to verify it is not discriminating. Collecting more of the same category of data would not make the system fairer; it would enlarge the attack surface for proxy discrimination while leaving the underlying survivorship bias untouched.

Deployment Decision Memo

Recommendation: NO-GO (Current Iteration)

The AI Talent Sourcing Assistant should not be deployed in the way described here. We failed to give the GDPR Article 13/14 notice as required by law (see Section 4). Therefore, the probability of this happening is almost 100% and the magnitude is Moderate, High so that it is, effectively, a real ongoing non-compliance that does not depend on any other promise made in the future. This problem together with the ones presented in Section 2, concerning proxy-discrimination are very likely not limited to the drop-out of one particular feature but will affect virtually every input in the system. A risk assessment that comes out as a high risk cannot simply be ignored unless you can defend the override decision in such a strong way that any reasonable person would accept it; however, the supporting evidence here is not so robust that this could be a case of an overriding Go without considering Conditional Go. Therefore, a No-Go recommendation is made in this paper instead of a Conditional Go, along with the very clear, independently verifiable roadmap in Section 5 to make way for a future Go decision. The justification provided by the five required factors is detailed below with the specific evidence that leads to the above conclusion instead of providing it as an abstract checklist which only gives a general overview and is disconnected from it.

1. Likelihood and Magnitude of Potential Harm

Likelihood is Near-certain, not speculative: the **Article 13/14** notice failure detailed in Section 4 is already occurring on the facts given, not a probabilistic future event. Solove and Hartzog (2025) describe exactly this pattern as “the great scrape” (the structural collision between AI's appetite for data and privacy law's demand for individual notice, control, and purpose limitation), and an employer combining applicant submitted resumes with an undisclosed, repurposed scrape of a professional-networking profile is a concrete instance of it, not an edge case. Magnitude is Moderate–High: the system scores every applicant who reaches it, so bias in the scoring logic reaches the full applicant pool on every hiring cycle rather than an isolated case, and a low cultural-fit or growth potential score can remove a candidate from recruiter review entirely, a severe, individualized, and largely invisible harm, since the applicant is never told LinkedIn data was used against them. Comparable real-world enforcement actions confirm this is not a theoretical risk: the EEOC's 2023 settlement with iTutorGroup (\$365,000) and the ongoing Mobley v. Workday litigation (N.D. Cal.) both involve AI hiring tools alleged to have produced exactly this kind of large-scale, low-visibility harm.

2. Potential Disparate Effects on Marginalized or Protected Groups

Proxy attributes are interwoven with virtually every aspect (feature) of the assessment, not just a single, stand-alone aspect: employment breaks indirectly reflect on sex, disability, and caregiver status; job position and educational qualifications indirectly indicate the candidate's nationality (immigration status) and socioeconomic status; the language in the profile mostly conveys the candidates' national origin, race/disability; and the affiliation/club data mostly reveals the person's race/religion/sex. The training of the system is based only on the applicants (data) that have been previously approved by the organization, the model is also biased as, the model reproduces the patterns from previous hiring decisions without evaluating the merit, the model will continue reproducing past hiring decisions rather than considering merit. These are, as such, major, overlapping threats running through the assessment system, every one of them adds to the Section 1 notice breach in the same direction an individual affected by a proxy is also the one never having been informed about the fact that the proxying data were collected from LinkedIn in the first place, thus the two harms can never become independently detectable or contestable.

3. Data-Governance Weaknesses

The audit underlying this assessment found a training population of unknown, unverified provenance; no independent data-governance or ethics reviewer distinct from the team that built and benefits from the model; a LinkedIn collection stream with no documented consent trail; and a likely over-collection of LinkedIn profile content (photographs, group memberships, connections) well beyond what is necessary to assess job-relevant qualifications. No documented process describes how the historical HR data was cleaned, curated, or validated before training: for example, whether duplicate or stale applications were removed, whether resumes were reliably matched to the correct LinkedIn profile, or whether the hiring-outcome labels used to define “cultural fit” and “growth potential” were checked against actual performance records rather than an unaudited manager impression. Without a governance function positioned to catch these gaps, and without documented lineage for the data that gap would need to examine, none of the downstream legal or fairness problems is likely to be caught before it reaches an applicant.

4. Legal and Compliance Concerns

The system's two data streams trigger two distinct, non-overlapping GDPR notice obligations, and treating them as one problem is the most common way an analysis like this one goes wrong (Dewitte, 2025, Ch. 7). Resumes are collected directly from the applicant and fall under **Article 13**, which requires disclosure of the purpose, legal basis, recipients, retention period, and, critically here, the existence of automated decision-making (**Art. 13(2)(f)**). LinkedIn profiles are obtained from a source other than the applicant and instead fall under **Article 14**, which additionally requires disclosing the categories of data and its source, within one month of collection or at first contact with the applicant if earlier (**Art. 14(3)**). **Article 14(5)**'s narrow disproportionate-effort exemption does not rescue the current practice: naming LinkedIn as a source in a privacy notice the organization already issues is not disproportionate effort by any reasonable reading. The scenario satisfies, at best, a thin version of **Article 13** for the resume stream and satisfies none of **Article 14** for the LinkedIn stream, and because the two duties are legally distinct, disclosing one does not discharge the other. This holds regardless of sourcing: if the LinkedIn data is instead purchased through a third-party vendor, the organization and vendor are joint controllers under **GDPR Article 26**, and the vendor contract does not transfer away the organization's own notice and lawful-basis obligations.

The notice failure is not the only lawful-basis problem: the system's asserted basis, legitimate interest under **Article 6(1)(f)**, fails its own balancing test, because the applicant's fundamental privacy interest in not having a LinkedIn profile scraped and profiled outweighs the organization's interest in faster candidate sorting. Legitimate interest could not cure this in any event for the special-category proxies discussed next: **Article 6(1)(f)** is not an available basis for **Article 9** data, which requires its own listed exception, ordinarily explicit consent under **Article 9(2)(a)**, one structurally impossible to obtain retroactively from profile data already scraped without the applicant's knowledge. Because no valid **Article 6** basis supports the processing, it remains unlawful independently of, and in addition to, the notice defects above.

This is a concrete instance of what Solove and Hartzog (2025) call “the great scrape”: personal data gathered from a platform built for professional networking, repurposed for automated candidate ranking without the knowledge of the people it describes. A LinkedIn profile scraped for this purpose is also a purpose-limitation problem independent of the notice failure (**GDPR Art. 5(1)(b)**), and the same profile's photo, group memberships, and connections carry far more than the minimization principle (**Art. 5(1)(c)**) permits for the stated purpose of assessing cultural fit and growth potential. Several of these same fields are not merely excessive under **Article 5**: affiliation memberships and unstructured profile text can function as proxies for **Article 9** special-category data (religion, health, sexual orientation), which GDPR prohibits processing without a narrow exception that is absent here. This is an **Article 9** problem, not only an **Article 5** one, and it

compounds rather than merely adds to the exposure already established, since special-category violations sit within the same top administrative-fine tier as the notice and **Article 6** violations above (**Art. 83(5)**).

The system is separately high-risk under the EU AI Act: **Article 6(2)**, read with **Annex III point 4(a)**, classifies AI systems used to analyze and filter job applications and to evaluate candidates as high-risk, and the ranking here is the mechanism that determines which applicants a recruiter reviews at all, a functional test the Act applies regardless of whether a human formally signs off on the final hire. **Article 6(3)** offers a narrow self-assessment filter, and none of its four conditions fits this system. It does not perform a purely procedural task, because cultural-fit and growth-potential scoring are substantive, judgment laden evaluations rather than clerical steps. It does not improve a previously completed human assessment, because the ranking is the first substantive evaluation the applicant pool receives, not a refinement of an assessment a person already made. It does not merely detect patterns or deviations for a separate human assessment to weigh, because the ranking itself (not an independent human review) determines which applicants receive attention in the first place. And it is not a preparatory task in the sense the filter intends, since it directly drives an employment relevant outcome rather than assembling inputs for one. The filter is independently unavailable on top of all four because the system performs profiling as the GDPR defines it (automated evaluation of personal aspects such as reliability or behavior), and scoring “cultural fit” is squarely that. High risk classification therefore stands, bringing the full **Chapter III** obligations (a risk-management system, data-governance documentation, technical documentation and logging, a genuine human-oversight design, accuracy and robustness testing, and a conformity assessment) into force before deployment, none of which is currently satisfied.

For an **Annex III** human-resources system, that conformity assessment follows the internal route under **Article 43** rather than third-party review: no notified body pre-approves the system, so the organization itself must compile the **Annex IV** technical documentation, complete the internal control assessment, affix the CE marking, and sign an EU declaration of conformity before the system is placed into use. The full burden of getting the assessment right therefore sits with the organization's own governance process, not with an external check that would catch a mistake later, which is one more reason the data-governance weaknesses in Section 3 are not a peripheral concern.

Beyond the GDPR and the AI Act, **Article 22**'s right against solely automated decisions with significant effects, and **Article 35(3)(a)**'s DPIA requirement for systematic profiling-based evaluation, both apply and are currently unaddressed: no DPIA has been completed. A recruiter nominally reviewing top ranked candidates does not, by itself, satisfy **Article 22**: EDPB-endorsed guidance requires human involvement to be meaningful, exercised by someone with authority to change the decision, not a token check on output the system already produced (Article 29 Working Party, 2018). Because the ranking itself, not an independent human judgment, determines which applicants a recruiter ever sees, the “human-in-the-loop” label does not discharge the **Article 22** obligation; it only relocates the automated decision to an earlier, unreviewed step. The same proxies also create ADA exposure, which the EEOC's 2022 algorithmic-decision-making guidance addresses directly (EEOC, 2022), and Title VII exposure. **NYC Local Law 144**'s bias audit requirements, which require calculating an impact ratio for sex and for race/ethnicity categories, would apply to comparable deployments and are illustrative of the broader U.S. trend. These are not a handful of independent, severable defects; they are the same undisclosed, unminimized, unaudited data practice viewed through several different bodies of law, which is why no single-feature fix or notice patch resolves them without the full roadmap in Section 5.

5. Mitigability of Identified Risks Before Deployment

The risks above are serious and, on the current record, legally uncured, which is why this memo recommends No-Go for the present iteration rather than a Conditional Go that would treat an active **Article 13/14** violation as something a future promise can offset. They are not, however, unfixable, and the same evidence that supports No-Go today defines exactly what a future Go decision would require.

Training the underlying model with differential privacy (for example, DP-SGD with an assumed privacy budget of $\epsilon \approx 2$ per training run) is an appropriate technical safeguard to include in that roadmap, though it must be scoped honestly rather than treated as a cure-all. A budget in this range sits deliberately between the very loose ϵ of 8–10 sometimes tolerated for low sensitivity tasks and the very tight ϵ well below 1 used for public statistical releases: it is tight enough to meaningfully bound how much any single applicant's combined resume-and-LinkedIn record can influence the trained model, while preserving enough statistical utility for the ranking to remain functional for its stated purpose. Reaching that equilibrium is a tuning problem, not a fixed setting: DP-SGD achieves it by clipping each record's per example gradient contribution and adding calibrated noise before every update, and pushing ϵ meaningfully below 1 would require enough added noise that the model could no longer reliably separate genuine growth potential signal from noise, destroying the ranking's utility for its stated purpose. Concretely, $\epsilon \approx 2$ bounds how much the presence or absence of any one applicant's record in the training data can change the probability of any particular model output (by a factor of at most $e^\epsilon \approx 7.4$), which is tight enough to make membership inference and model inversion reconstruction of an individual applicant's resume-and-LinkedIn dossier statistically unreliable, without flattening the score distribution so much that the ranking loses its ability to differentiate candidates for its stated business purpose.

That safeguard is time-limited as well, to be precise, it only protects a set of historical candidates whose data was included to train the machine learning model. It does not, however, protect the present candidate whose LinkedIn profile is accessed and scored when we perform live inference. This type of harm from live data access is entirely captured by Sections 1 and 4 and no protection that could have been enacted at training time would have protected you. The other thing you get by differential privacy is also to be clearly understood, in short, it is a privacy preserving technique rather than a way to promote fairness. Therefore, it has no effect on the proxy-discrimination channels from Section 2 or on the notice failure problems from Section 4. You are right to say that it fits nicely into the list of the measures discussed below in combination with the notice and bias audit requirements, but not as a substitute for them.

Before the system can be reconsidered for a Go decision, the organization must complete and independently verify each of the following:

- **Itemized GDPR Notice:** Provide a specific, itemized notice disclosing LinkedIn collection and use, satisfying **GDPR Article 13** and **Article 14**, before any applicant data is collected.
- **Data Ingestion Restriction:** Restrict LinkedIn ingestion to job-relevant structured fields only, removing photographs, group affiliations, connection lists, and free-text profile language from the scoring pipeline.
- **Independent Bias Audit:** Commission an independent bias audit against the proxy variables identified in Section 2, testing formally for demographic parity and equal-opportunity gaps across protected groups, using a stratified, purpose-limited demographic sample collected under separate consent, never fed into the scoring model itself.
- **Formal DPIA and Conformity Package:** Complete a formal Data Protection Impact Assessment under **GDPR Article 35** and the **Article 43** internal conformity package (technical documentation, CE marking, and declaration of conformity) under the EU AI Act before go-live.
- **Explainable Human Review:** Provide applicants a meaningful right to human review of an automated ranking decision, consistent with **GDPR Article 22**, and instrument the scoring pipeline with a local feature-attribution method (e.g., SHAP or LIME). Recital 71's right to an explanation is not satisfied by a black-box score: a reviewer can only meaningfully override a proxy-driven result if told, for example, that a candidate's score was lowered by roughly 15% because of an "Employment Gap" feature, rather than being handed a number with no reason attached. This also anchors **EU AI Act Article 14**'s human-oversight mandate, which requires high-risk systems to be designed against automation bias: without feature-level attribution, a recruiter cannot meaningfully interpret or contest

the ranking and is left rubber-stamping it, the exact failure mode **Article 14** requires the design to guard against.

- **Differential Privacy Implementation:** Train the model under differential privacy (DP-SGD) at an assumed budget of $\epsilon \approx 2$, as a supplementary safeguard against re-identification in any aggregate bias-audit reporting, understood as addressing disclosure risk only.

The notice and DPIA/conformity conditions are meant to solve the Near-certain Article 13/14 violation and the Article 43 gap in Section 4; the bias audit verified against explicit fairness metrics solves the proxy-discrimination pathways described in Section 2; the explainable-review requirement and differential-privacy training are solutions for the data-governance and re-identification gaps in Section 3. The notice violation will remain valid, and the proxy pathways untested, until all these six conditions are not only completed but also verified by an outsider, and not just a planning one. A law violation that is still in progress and that at the same time the discrimination risk is a scenario that is not even tested is just like a high-risk-score-with-Go-anyway situation, which a defensible assessment cannot just dismiss without the brief being strong enough. This memo's evidence does not be strong enough to do so today. That is what explains the No-Go decision and that is the unique, testable way a Go decision in the future should be assessed.

References

- Article 29 Working Party. (2018). Guidelines on automated individual decision-making and profiling (WP251rev.01).
- Dewitte, P. (2025). AI meets the GDPR: Navigating the impact of data protection on AI systems (Chapter 7). In N. A. Smuha (Ed.), *The Cambridge handbook of the law, ethics and policy of artificial intelligence*. Cambridge University Press. <https://doi.org/10.1017/9781009367783>
- Mobley v. Workday, Inc., No. 3:23-cv-00770-RFL (N.D. Cal. filed 2023).
- National Institute of Standards and Technology. (2022). Towards a standard for identifying and managing bias in artificial intelligence (NIST Special Publication 1270). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.1270>
- New York City, N.Y., Local Law 144 of 2021, Automated Employment Decision Tools, N.Y.C. Admin. Code § 20-870 et seq.
- Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data (General Data Protection Regulation).
- Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act).
- Solove, D. J., & Hartzog, W. (2025). The great scrape: The clash between scraping and privacy. *California Law Review*, 113, 1521.
- U.S. Equal Employment Opportunity Commission. (2022). The Americans with Disabilities Act and the use of software, algorithms, and artificial intelligence to assess job applicants and employees.
- U.S. Equal Employment Opportunity Commission v. iTutorGroup, Inc., No. 1:22-cv-02565 (E.D.N.Y. settled 2023).

AI Assistance: Used Grammarly for minor editing only.